COURSE LAB GUIDE · 32 LABS · 6 PARTS

Technology & Security Governance: Lab Guide

Hands-on exercises for every video in the course. Each lab produces one artifact for a single fictional organization; by Lab 29 those artifacts assemble into a complete, operating governance program.

THE SPINE — RETURN TO IT AT EVERY PART BOUNDARY

Governance

Sets direction, assigns decision rights, holds to account. Asks: right things? well enough? who answers?

Management

Plans and runs the work within the direction governance sets, and reports back on it.

Controls

Do the work: the technical and procedural safeguards that actually reduce risk.

How to use this guide

Complete each lab after its video, in order. Labs build on one another: the **Inputs** line names the earlier artifacts you will need open. Keep every artifact in a single folder named for the case-study organization — that folder is your governance record, and Lab 11 turns it into an evidence structure.

Every lab follows the same format:

- **Objective** — the single capability the lab builds.
- **Inputs** — prior artifacts and materials required.
- **Steps** — the work, in order. Write your answers down; governance that is not recorded did not happen.
- **Deliverable** — the artifact you file when finished.
- **Check your work** — criteria to self-assess before moving on.

Time estimates assume you have watched the video. Where a lab asks for a decision, make one and record your reasoning; there is rarely a single right answer, but there is always an accountable one.

The case study: Corbel Medical Supply

You will build this organization out fully in Lab 3. Use the starting brief below, or substitute an organization you know well — as long as it has real assets, real regulators and a real board.

Business	Regional distributor of medical and surgical supplies to clinics and hospitals; online ordering portal and own warehouse fleet.
Size	~1,400 employees, ~$420M annual revenue, operations in the US and two EU countries.
Data	Customer and payment card data; some patient-linked delivery records; supplier contracts; logistics telemetry.
Obligations	Privacy law (US state and EU), card-industry standard, health-data rules via customer contracts, product traceability.
Starting state	Ad hoc: an IT director who "also does security," no risk register, policies copied from a template three years ago, a board that has never discussed cyber risk.

Lab index

LAB	TITLE	ARTIFACT
01	What Governance Actually Is	Governance / management / controls model
02	Why Governance Fails and Why It Matters	Governance failure catalog
03	Building Your Governance Case Study	Case-study organization profile
04	The Governance Mindset and Method	Governance decision framework
05	The Governance Landscape: Frameworks and Standards	Framework selection matrix
06	Governance Structures and Decision Rights	Structure and decision-rights matrix
07	The Board and Executive Governance	Board oversight charter
08	Roles, Responsibilities, and the CISO	Governance RACI matrix
09	Securing Buy-In and Governing Across the Organization	Stakeholder engagement plan
10	Policies, Standards, and Procedures	Policy framework and sample policy

LAB	TITLE	ARTIFACT
11	Governance Documentation and Evidence	Documentation and evidence structure
12	Risk Management Fundamentals	Risk appetite statement and lifecycle
13	Risk Identification and Assessment	Top-risk assessment
14	Risk Treatment and the Risk Register	Risk register with owners
15	Third-Party and Supply Chain Risk	Third-party risk process and assessment
16	Business Continuity and Operational Resilience Governance	Continuity governance structure
17	Emerging and Strategic Risk	Strategic and emerging risk assessment
18	Compliance Fundamentals and the Regulatory Landscape	Obligations inventory
19	Major Regulations and Frameworks in Depth	Regulation-to-control mapping
20	Building a Compliance Program	Compliance program design
21	Audit, Assessment, and Assurance	Audit-readiness framework
22	Metrics, Reporting, and Communicating Governance	Reporting framework and board dashboard
23	Governing Security Operations and Incident Response	Security operations governance structure
24	Governance Strategy and Alignment	Strategy and maturity roadmap
25	The Economics of Governance and Security Investment	Investment case and budget framework
26	Governing People, Culture, and Awareness	Culture and awareness program
27	Ethics, Privacy, and Responsible Technology Governance	Ethics and responsible-technology framework
28	Governing Emerging Technology and AI	Emerging technology and AI framework
29	Building and Running the Governance Program End to End	Integrated governance program

LAB	TITLE	ARTIFACT
30	When Governance Fails	Failure-mode audit
31	Assessing and Maturing a Governance Program	Self-assessment and improvement roadmap
32	Your Path Forward	Skills self-assessment and development plan

PART I · LABS 01–04

Foundations

Fix the vocabulary, face the failure record, build the organization you will govern, and learn to think like a governance professional rather than an implementer.

LAB 01 · VIDEO 1 — 45 MIN

What Governance Actually Is

Objective. Distinguish governance, management and controls precisely enough to classify any activity correctly.

Inputs. Video 1 notes. A blank one-page template divided into three columns.

STEPS

1. Write a one-sentence definition of governance in your own words that names direction, decision rights and accountability.
2. Head three columns Governance, Management, Controls. Under each, write what it does, who typically performs it, and what evidence it leaves.
3. Classify these twelve activities into the columns: approving risk appetite; patching servers; setting the security budget; running a phishing simulation; approving an access policy; configuring MFA; reviewing quarterly risk reports; assigning a project manager; a firewall rule; choosing to enter a new market with known data risks; scheduling backups; dismissing an accountable executive.
4. For three activities that felt ambiguous, write one line on why — then decide.
5. Add the three governance questions across the top of the page so the model is self-explanatory.

DELIVERABLE

A one-page model with definitions, the three-column distinction, worked classifications and the three governance questions.

CHECK YOUR WORK

- Nothing in the Governance column is something a technician would do day to day.
- Every control you listed could be traced back to a management decision and a governance direction.
- A colleague could use the page without you explaining it.

LAB 02 · VIDEO 2 60 MIN

Why Governance Fails and Why It Matters

Objective. Recognize governance failure patterns in real incidents and separate them from control failures.

Inputs. Lab 1 model. Three public breach or regulatory-penalty reports of your choosing.

STEPS

1. For each incident, write a three-sentence summary: what happened, the immediate technical cause, and the cost.
2. Ask of each: who was accountable for the control that failed, and did they know it? Record the answer or "nobody."
3. Tag each incident with one or more failure patterns: accountability gap, alignment failure, tone at the top, bureaucracy trap, unfollowed policy, invisible-until-failure underfunding.
4. Build the catalog as a table: pattern, description, real example, warning signs, the question that would have caught it.
5. Add at least one row for the opposite failure — governance so heavy it strangled the work.

DELIVERABLE

A governance failure catalog of at least six patterns, each with a real example, warning signs and a diagnostic question.

CHECK YOUR WORK

- Each example traces to a governance failure, not only a missing control.
- Warning signs are observable before an incident.
- The diagnostic questions could be asked in a real meeting.

LAB 03 · VIDEO 3 90 MIN

Building Your Governance Case Study

Objective. Build a specific, realistic organization against which every later lab is practiced.

Inputs. The Corbel Medical Supply brief (or your substitute). Video 3 notes.

STEPS

1. Describe the business model: what the organization sells, to whom, and how it makes money. Name its top three business objectives for the next two years.

2. List its critical assets and data. For each, write what would genuinely hurt if it were lost, altered or exposed — in business terms.
3. Draft an initial list of regulatory and contractual obligations. Do not research deeply yet; Part IV will.
4. Sketch the leadership structure: board composition, CEO, direct reports, and who currently owns technology and security.
5. Describe the current, immature state honestly: what exists, what is missing, what has gone wrong recently.
6. Map stakeholders across business, technology, security, legal and finance, with one line on what each wants from governance.

DELIVERABLE

A complete organization profile (2–4 pages) filed as the first record in your governance folder.

CHECK YOUR WORK

- The profile is specific enough that two readers would make the same risk calls.
- Assets are described by business impact, not just technical category.
- The starting state is believably imperfect.

LAB 04 · VIDEO 4 60 MIN

The Governance Mindset and Method

Objective. Adopt a repeatable method for approaching any governance question.

Inputs. Labs 1 and 3.

STEPS

1. Write the five-step method as a checklist: understand objectives, identify risks to them, assign accountability, set direction, verify it is followed.
2. Under each step, add two or three prompting questions. Open the accountability step with: who is responsible, who decides, who answers when it goes wrong?
3. Add an "outcome test": what evidence would show risk is actually being managed, not merely worked on?
4. Apply the framework to this scenario: Corbel's sales team wants to launch a customer self-service portal in six weeks using a new SaaS platform.
5. Note where you would need influence rather than authority, and where too much oversight would harm the business.

DELIVERABLE

A one-page decision framework plus a worked application to the portal scenario.

CHECK YOUR WORK

- The worked scenario ends in a named decision-maker and a verification mechanism.
- You did not take ownership of a risk that belongs to the business.
- The outcome test measures results, not activity.

PART II · LABS 05–11

Structures, Roles and Instruments

Assemble the machinery: frameworks, decision rights, the board, the people who carry accountability, the influence that makes it work, and the documents and records that express and prove it.

LAB 05 · VIDEO 5 — 75 MIN

The Governance Landscape: Frameworks and Standards

Objective. Select a combination of frameworks that fits the organization rather than adopting one as dogma.

Inputs. Lab 3 profile. Summaries of COBIT, NIST CSF, ISO 27001, the CIS Controls and one risk framework (e.g. ISO 31000 or NIST RMF).

STEPS

1. Classify each framework as governance, control or risk framework, with one line on what it gives you.
2. List Corbel's selection criteria: industry, size, regulatory environment, customer expectations, current maturity, budget.
3. Score each framework against each criterion (1–3) in a matrix.
4. Choose a combination. State which framework is the primary structure and how the others map into it.
5. Write two sentences on how you will stop the chosen frameworks becoming a checklist divorced from risk.

DELIVERABLE

A framework selection matrix with scores, the chosen combination and the rationale.

CHECK YOUR WORK

- The combination covers governance, control and risk roles.
- Any certification goal is justified by a business driver.
- The choice would still make sense to Corbel's CFO.

LAB 06 · VIDEO 6 90 MIN

Governance Structures and Decision Rights

Objective. Design a governance structure in which no significant decision falls through a gap.

Inputs. Labs 3 and 5.

STEPS

1. Draw the hierarchy from board to executive to management, and write what belongs at each level.
2. List twenty recurring governance decisions (e.g. approve risk appetite, accept a high residual risk, approve a policy exception, choose a cloud provider).
3. Build a decision-rights matrix: for each decision, who proposes, who decides, who must be consulted, who can veto.
4. Design up to three committees. For each give a mandate, membership, cadence, quorum and the decisions it owns. Remove any committee that owns no decisions.
5. Map Corbel's functions onto the three lines model and choose centralized or federated governance, with reasons.

DELIVERABLE

An organization chart of governance bodies, committee charters in brief, and the decision-rights matrix.

CHECK YOUR WORK

- Every one of the twenty decisions has exactly one decider.
- Each committee has authority to decide something, not only to discuss.
- The third line is genuinely independent of the first two.

LAB 07 · VIDEO 7 75 MIN

The Board and Executive Governance

Objective. Define what Corbel's board must oversee and how it will know it is doing so.

Inputs. Labs 3 and 6.

STEPS

1. Decide which board committee (full board, audit, or risk) holds technology and security oversight, and why.

2. Write the board's responsibilities: approving appetite, overseeing major risks, holding executives to account, ensuring adequate resources.
3. Draft ten questions directors should ask management at least annually about risk and security.
4. Specify reporting: what the board receives, from whom, how often, and what triggers an out-of-cycle briefing.
5. Add a short section on director education and on the accountability that cannot be delegated.

DELIVERABLE

A two-page board oversight charter for technology and security risk.

CHECK YOUR WORK

- The charter distinguishes overseeing from managing.
- Director questions cannot be answered with "yes, we have a policy."
- Escalation triggers are specific and measurable.

LAB 08 · VIDEO 8 90 MIN

Roles, Responsibilities, and the CISO

Objective. Assign clear responsibility and accountability for every governance function.

Inputs. Labs 3, 6 and 7.

STEPS

1. Decide whether Corbel needs a CISO, and where the role reports. Document the trade-off in authority and independence for at least two reporting lines.
2. List the executive roles involved: CEO, CIO/CTO, CISO, CFO, General Counsel, privacy lead, risk and compliance leads, business unit heads.
3. List at least fifteen governance functions (policy approval, risk register maintenance, incident declaration, vendor approval, audit liaison, access reviews…).
4. Build the RACI. Enforce one A per row.
5. Find every row where the A lacks authority over the R. Resolve it or record it as a known accountability-without-authority risk.

DELIVERABLE

A complete RACI matrix with a reporting-line decision for the CISO.

CHECK YOUR WORK

- Exactly one Accountable per function.
- No function is Accountable to a role that does not exist yet without a plan to fill it.
- The CISO is not accountable for business risks they cannot control.

LAB 09 · VIDEO 9 75 MIN

Securing Buy-In and Governing Across the Organization

Objective. Plan the influence work needed to launch governance across departments you do not control.

Inputs. Labs 3, 6 and 8.

STEPS

1. List each stakeholder group from Lab 3 and rate their current support and influence.
2. For business, engineering, finance and legal, write the pitch in their language: what governance does for their objectives.
3. Identify what each group fears losing (speed, budget, autonomy) and how the design minimizes that cost.
4. Plan a launch sequence: who to win first, through which forums, with what early win.
5. Define three culture signals you will watch to know whether governance is believed in or merely tolerated.

DELIVERABLE

A stakeholder engagement plan with tailored messages, a launch sequence and culture signals.

CHECK YOUR WORK

- Each pitch names a benefit the stakeholder already wants.
- The plan includes listening, not only telling.
- Culture signals are observable behaviors.

LAB 10 · VIDEO 10 120 MIN

Policies, Standards, and Procedures

Objective. Build a document hierarchy and write one policy people will actually follow.

Inputs. Labs 5, 6, 8 and 9.

STEPS

1. Define the four document types — policy, standard, procedure, guideline — with who approves each and how often each is reviewed.
2. List the policies Corbel needs (aim for 8–12, not 40). For each, name its owner and its supporting standards.
3. Write one complete policy (e.g. Access Control or Acceptable Use): purpose, scope, statements of direction, roles, compliance, exceptions, review. Keep it under two pages.
4. Write one standard beneath it with specific, mandatory, testable requirements.
5. Design the exception process: request, risk assessment, approver by risk level, expiry, register.

DELIVERABLE

A policy framework (hierarchy, inventory, lifecycle, exception process) and one full sample policy with a supporting standard.

CHECK YOUR WORK

- The policy states intent; technical detail lives in the standard.
- Every requirement in the standard could be tested by an auditor.
- Exceptions expire and are visible.

LAB 11 · VIDEO 11 60 MIN

Governance Documentation and Evidence

Objective. Design governance so its records are a byproduct of operating it.

Inputs. Labs 6, 7, 8 and 10.

STEPS

1. List every record governance should produce: charters, minutes, decisions, approvals, exceptions, risk acceptances, reports.
2. Design a decision record template: what was decided, by whom, under what authority, on what information, with what dissent.

3. For each record, define owner, location, retention period and access.
4. Identify which records can be generated automatically by tools Corbel already uses.
5. Test reconstructability: pick a decision from Lab 4 and check you could explain it to a regulator two years from now.

DELIVERABLE

An evidence structure (record inventory, templates, retention rules) and a populated decision record.

CHECK YOUR WORK

- Each record has a single owner.
- The decision template captures basis and authority, not just outcome.
- At least a third of evidence is produced by operating, not by extra work.

PART III · LABS 12–17

Risk

Build the engine that drives every governance decision — from appetite to assessment, treatment, third parties, resilience and the risks not yet on the register.

LAB 12 · VIDEO 12 — 75 MIN

Risk Management Fundamentals

Objective. Define how much risk Corbel will accept and how it will manage risk continuously.

Inputs. Labs 3, 6 and 7.

STEPS

1. Write definitions for threat, vulnerability, likelihood, impact, inherent risk, residual risk, appetite and tolerance in Corbel's terms.
2. Draft a risk appetite statement across at least five categories (e.g. data protection, operational availability, regulatory, financial, reputational). Use qualitative levels plus at least one measurable tolerance per category.
3. Identify who must approve the appetite and record why it is a leadership decision.
4. Draw the identify–assess–treat–monitor lifecycle for Corbel, with cadence and owner at each stage.
5. State what happens when a risk exceeds tolerance.

DELIVERABLE

A board-ready risk appetite statement and a documented risk management lifecycle.

CHECK YOUR WORK

- Tolerances are measurable.
- Appetite differs across categories.
- The lifecycle ends in decisions, not only reports.

LAB 13 · VIDEO 13 120 MIN

Risk Identification and Assessment

Objective. Identify and rate Corbel's most significant risks with an explicit, repeatable method.

Inputs. Labs 3 and 12.

STEPS

1. Identify at least fifteen risks using both an asset-based pass and a scenario-based pass. Draw on threats, incident history and planned business change.
2. Write each risk as a sentence: cause, event, consequence.
3. Define a 5×5 qualitative scale with written criteria for each likelihood and impact level.
4. Rate inherent risk for each. Note the assumptions behind every rating of 4 or 5.
5. Quantify the top two risks in financial terms (annualized loss range). Compare the result with the qualitative rating.
6. List the biases that may have shaped your ratings and adjust where warranted.

DELIVERABLE

A completed risk assessment ranking the top ten risks, with criteria, assumptions and two quantified examples.

CHECK YOUR WORK

- Each risk statement names a business consequence.
- Ratings are traceable to written criteria.
- Quantification uses ranges, not false precision.

LAB 14 · VIDEO 14 120 MIN

Risk Treatment and the Risk Register

Objective. Decide a treatment for every top risk and track it with named owners.

Inputs. Labs 8, 12 and 13.

STEPS

1. Design the register fields: ID, statement, category, owner, inherent rating, treatment, controls, residual rating, acceptance, review date, status.
2. Choose accept, mitigate, transfer or avoid for each top risk, with a one-line rationale.
3. For mitigated risks, name the controls and estimate cost against the risk reduction.

4. For accepted residual risks, name who has authority to accept at that level and record the acceptance.
5. Assign every risk a named business owner and set a review cadence.

DELIVERABLE

A populated risk register for Corbel's top ten risks.

CHECK YOUR WORK

- No risk is owned by "IT" or "Security" as a department.
- Every residual risk above appetite is either treated further or formally accepted by an authorized person.
- No control costs more than the risk it reduces without a stated reason.

LAB 15 · VIDEO 15 90 MIN

Third-Party and Supply Chain Risk

Objective. Govern the risk that lives with Corbel's vendors and their vendors.

Inputs. Labs 3, 13 and 14.

STEPS

1. List Corbel's key third parties and tier them by data access, criticality and replaceability.
2. Design the lifecycle: selection, due diligence, contracting, onboarding, monitoring, offboarding — with an owner per stage.
3. Build a vendor assessment questionnaire scaled by tier; keep the lowest tier under 15 questions.
4. Draft minimum contract clauses: security requirements, audit rights, breach notification, subcontractor disclosure, exit.
5. Identify one fourth-party dependency and one concentration risk. Add them to the register.

DELIVERABLE

A third-party risk management process, tiered assessment framework and contract clause set.

CHECK YOUR WORK

- Assessment effort scales with risk.
- Monitoring continues after onboarding.
- At least one concentration risk is on the register.

LAB 16 · VIDEO 16 75 MIN

Business Continuity and Operational Resilience Governance

Objective. Connect leadership accountability to Corbel's ability to absorb and recover from disruption.

Inputs. Labs 3, 6, 14 and 15.

STEPS

1. Run a lightweight business impact analysis on Corbel's five most important business services: maximum tolerable disruption and dependencies.
2. Define who owns continuity at board, executive and service level.
3. Map each service to its recovery capability and identify gaps.
4. Set a testing program: what is exercised, how often, who must attend, how results reach leadership.
5. Note any regulatory or customer-contract resilience requirements.

DELIVERABLE

A continuity governance structure linking leadership, critical services, recovery capability and testing.

CHECK YOUR WORK

- Recovery priorities come from business criticality.
- Leadership attends at least one exercise per year.
- Each critical service has a named owner.

LAB 17 · VIDEO 17 75 MIN

Emerging and Strategic Risk

Objective. Look two to three years ahead and govern risks not yet on the register.

Inputs. Labs 3, 13 and 14.

STEPS

1. Restate Corbel's strategic objectives and identify technology or security risks that threaten each.
2. Horizon-scan across technology (including AI), regulation, geopolitics and systemic dependencies. List at least eight signals.
3. Rate each by potential impact and time to materialize.
4. Choose three to escalate: write the risk statement, an early-warning indicator and a decision leadership must make now.

5. Identify one emerging technology Corbel should adopt and describe how governance can enable rather than block it.

DELIVERABLE

A two-to-three-year strategic and emerging risk assessment with three escalated risks.

CHECK YOUR WORK

- Strategic risks are not operational risks restated.
- Each escalated risk has an early-warning indicator.
- The enablement case is genuine.

PART IV · LABS 18–23

Compliance, Assurance and Oversight

Turn obligations into a sustainable program, prove that controls work, report it to people who can act, and govern the operational security function.

LAB 18 · VIDEO 18 — 90 MIN

Compliance Fundamentals and the Regulatory Landscape

Objective. Know every requirement Corbel is actually subject to.

Inputs. Labs 3 and 15.

STEPS

1. List obligations by category: privacy, security, financial, sector-specific, contractual.
2. For each, record the source, the jurisdiction, what it requires in a sentence, the owner, and the penalty for breach.
3. Identify customer and partner contracts that impose requirements beyond law.
4. Find at least one conflict between jurisdictions and propose how to reconcile it.
5. Mark where Corbel is compliant on paper but may be exposed in practice.

DELIVERABLE

A regulatory and contractual obligations inventory.

CHECK YOUR WORK

- Contractual obligations are included.
- Each obligation has an owner.
- At least one conflict is identified and resolved.

LAB 19 · VIDEO 19 — 120 MIN

Major Regulations and Frameworks in Depth

Objective. Translate legal obligations into specific controls that satisfy them.

Inputs. Labs 5, 10 and 18.

STEPS

1. Select Corbel's four most significant obligations.
2. Break each into individual, testable requirements.
3. Map each requirement to existing or planned controls and to the policy or standard that mandates them.
4. Document breach notification clocks for each regime and who starts the clock.
5. Mark each mapping satisfied, partially satisfied or gap, with evidence for "satisfied."

DELIVERABLE

A control mapping showing how Corbel's controls satisfy its key obligations, with gaps identified.

CHECK YOUR WORK

- Each "satisfied" cites evidence.
- Notification deadlines are reconciled into one incident timeline.
- Interpretations of ambiguous requirements are recorded.

LAB 20 · VIDEO 20 90 MIN

Building a Compliance Program

Objective. Turn scattered obligations into a sustainable program.

Inputs. Labs 11, 18 and 19.

STEPS

1. Define program elements: ownership, control library, evidence collection, monitoring, reporting, calendar.
2. Rationalize controls: merge mappings so one control satisfies multiple obligations. Record the reduction in control count.
3. For the ten most important controls, define how compliance is shown continuously rather than at audit time.
4. Build a twelve-month compliance calendar of assessments, attestations, renewals and reviews.
5. Define monitoring metrics that reveal drift between audits.

DELIVERABLE

A compliance program design with a rationalized control set and calendar.

CHECK YOUR WORK

- Control count is lower than the sum of obligations.
- At least half of key controls have continuous evidence.
- The calendar avoids year-end pile-ups.

LAB 21 · VIDEO 21 90 MIN

Audit, Assessment, and Assurance

Objective. Make Corbel always ready for independent verification.

Inputs. Labs 6, 11, 19 and 20.

STEPS

1. Define the assurance map: which controls are covered by internal audit, external audit and independent assessment.
2. Design a control-testing approach covering design and operating effectiveness, sample sizes and frequency.
3. Test one control from Lab 20 yourself and document the result.
4. Write an audit-readiness checklist: evidence locations, contacts, protocol for requests and findings.
5. Define how findings are tracked, owned and closed.

DELIVERABLE

An audit-readiness framework, control-testing approach and one documented test.

CHECK YOUR WORK

- Testing distinguishes design from operation.
- Third-line independence is preserved.
- Findings have owners and due dates.

LAB 22 · VIDEO 22 120 MIN

Metrics, Reporting, and Communicating Governance

Objective. Make governance visible at the level each audience can act on.

Inputs. Labs 7, 12, 14, 20 and 21.

STEPS

1. List twenty candidate metrics, then strike the vanity ones.
2. Define five to seven key risk indicators tied to appetite tolerances and five key performance indicators for the program.
3. Design reporting tiers for board, executive and operational audiences.
4. Build a one-page board dashboard: top risks against appetite, compliance posture, notable incidents, decisions required.
5. Write a one-paragraph narrative that tells the board what changed and what they need to decide.

DELIVERABLE

A governance reporting framework and a board-level dashboard.

CHECK YOUR WORK

- Each KRI maps to a tolerance from Lab 12.
- The dashboard asks for at least one decision.
- A non-technical director understands it in five minutes.

LAB 23 · VIDEO 23 — 90 MIN

Governing Security Operations and Incident Response

Objective. Connect leadership to the operational security capability without micromanaging it.

Inputs. Labs 6, 8, 16, 19 and 22.

STEPS

1. Map security capabilities (detection, response, threat intelligence, vulnerability management) with owners and reporting lines.
2. Define incident decision rights: who declares, who escalates, who authorizes shutdown, who notifies regulators, who speaks publicly.
3. Set escalation thresholds tied to business impact.
4. Define intelligence requirements: decisions leadership needs threat intelligence to inform.
5. Choose four security operations metrics that reach the executive level.

DELIVERABLE

A security operations governance structure with incident decision rights.

CHECK YOUR WORK

- Every major incident decision has one named authority and a deputy.
- Notification timelines from Lab 19 are integrated.
- Metrics measure effectiveness, not volume.

PART V · LABS 24-28

Strategy, Economics, People and Emerging Technology

Sustain the program: align it to strategy, fund it honestly, govern the human dimension, go beyond compliance into ethics, and direct technology that outpaces its rules.

LAB 24 · VIDEO 24 — 120 MIN

Governance Strategy and Alignment

Objective. Align governance and security to Corbel's objectives and plan multi-year evolution.

Inputs. Labs 3, 13, 17 and 22.

STEPS

1. Restate Corbel's objectives and write how governance and security serve each.
2. Assess current maturity across structure, risk, compliance, assurance, people and reporting on a 1–5 scale.
3. Set target maturity per domain, justified by risk and objectives.
4. Prioritize initiatives; cut anything that does not advance a business objective or reduce a top risk.
5. Lay out a three-year roadmap in phases with dependencies and budget assumptions.

DELIVERABLE

A governance and security strategy with a multi-year maturity roadmap.

CHECK YOUR WORK

- Not every domain targets level 5.
- Each initiative links to an objective or risk.
- Year one is achievable within a realistic budget.

LAB 25 · VIDEO 25 90 MIN

The Economics of Governance and Security Investment

Objective. Fund the program honestly and defend it credibly.

Inputs. Labs 13, 14 and 24.

STEPS

1. Account for the program's full cost: people, tools, external assurance, time from the business.
2. Select the top three investments from Lab 24 and frame each as risk reduction using quantified estimates.
3. Write a business case for the largest, including the cost of doing nothing and a conservative value estimate.
4. Design a budget framework: categories, allocation by risk priority, review process.
5. Assess whether cyber insurance belongs in the mix, and what it does not cover.

DELIVERABLE

A security investment case and budget framework.

CHECK YOUR WORK

- Value claims use conservative ranges and stated assumptions.
- Spend ranks by risk, not by vendor pitch.
- Insurance limits are explicit.

LAB 26 · VIDEO 26 90 MIN

Governing People, Culture, and Awareness

Objective. Govern the human behavior on which every policy and control depends.

Inputs. Labs 9, 10 and 14.

STEPS

1. Identify the five behaviors that matter most for Corbel's top risks.
2. Design awareness activity aimed at those behaviors, by audience, rather than generic annual training.
3. Define how you will measure behavior change, not completion rates.
4. Specify governance of insider risk, including joiner–mover–leaver controls with HR.

5. Describe how accountability culture is reinforced: recognition, consequences, leadership modeling.

DELIVERABLE

A security culture and awareness program design.

CHECK YOUR WORK

- Metrics measure behavior.
- Offboarding removes access within a defined time.
- Leaders have visible roles.

LAB 27 · VIDEO 27 75 MIN

Ethics, Privacy, and Responsible Technology Governance

Objective. Govern what Corbel should do, not only what it must.

Inputs. Labs 3, 18 and 26.

STEPS

1. Write five principles for Corbel's use of data and technology.
2. Review one data practice (e.g. delivery-driver telemetry) against legal minimums and your principles. Note the gap.
3. Define boundaries for employee monitoring: what, why, who sees it, how long it is kept.
4. Design an ethics review step for new data uses: triggers, reviewers, criteria, record.
5. Write how Corbel will explain significant technology decisions to those affected.

DELIVERABLE

An ethics and responsible-technology governance framework with one worked review.

CHECK YOUR WORK

- At least one practice is legal but changed on ethical grounds.
- Monitoring has proportionality limits.
- The review step has a clear owner.

LAB 28 · VIDEO 28 90 MIN

Governing Emerging Technology and AI

Objective. Govern technology arriving faster than the rules for it.

Inputs. Labs 17 and 27.

STEPS

1. Inventory AI and emerging technology already in use at Corbel, including shadow use.
2. Define AI risk tiers by impact and autonomy, with oversight required at each tier.
3. Assign accountability for each AI system, including autonomous agents acting without a human in the loop.
4. Design a fast-path approval for low-risk adoption that keeps rigor where it matters.
5. List emerging AI obligations Corbel should track and who monitors them.

DELIVERABLE

An emerging-technology and AI governance framework.

CHECK YOUR WORK

- Every AI system has an accountable human owner.
- Low-risk adoption is fast.
- Bias, opacity and new attack surfaces are addressed.

PART VI · LABS 29–32

Integration and Mastery

Assemble the whole program, attack it for failure modes, assess its maturity, and plan your own path forward.

LAB 29 · VIDEO 29 — 180 MIN

Building and Running the Governance Program End to End

Objective. Assemble all prior artifacts into one coherent, operating program.

Inputs. All artifacts from Labs 1–28.

STEPS

1. Write a one-page program overview tied to Corbel's objectives.
2. Assemble the structure, roles and decision rights (Part II) and resolve inconsistencies.
3. Connect the risk engine (Part III) to committee agendas and decisions.
4. Link compliance and assurance (Part IV) to evidence and reporting.
5. Integrate strategy, economics and people (Part V) into the annual cycle.
6. Build the operating rhythm: a twelve-month calendar of committees, reviews, reports, tests and decisions.

DELIVERABLE

A complete, integrated governance program document with an operating calendar.

CHECK YOUR WORK

- Artifacts reference each other consistently.
- Every committee meeting has input reports and expected decisions.
- The program runs without its author.

LAB 30 · VIDEO 30 — 90 MIN

When Governance Fails

Objective. Attack your own program for the failure modes that sink governance.

Inputs. Labs 2 and 29.

STEPS

1. Turn the Lab 2 catalog and Video 30 failure modes into audit questions.
2. Run each question against the Lab 29 program; record pass, partial or fail with evidence.
3. Hunt for bureaucracy: identify any process whose cost exceeds its risk value.
4. For each fail, design a fix and assign an owner.
5. Write a one-paragraph verdict on the program's most likely way to fail.

DELIVERABLE

A completed governance failure-mode audit with remediation actions.

CHECK YOUR WORK

- At least one honest fail is found.
- Fixes address process, not only documents.
- The verdict is specific.

LAB 31 · VIDEO 31 — 90 MIN

Assessing and Maturing a Governance Program

Objective. Build a self-assessment the program runs against itself on a regular cadence.

Inputs. Labs 22, 24, 29 and 30.

STEPS

1. Re-score maturity using the Lab 24 model, citing evidence.
2. Run a gap analysis between current and target state.
3. Perform an alignment check: does each component still serve an objective?
4. Perform an effectiveness check: is risk managed, or merely documented?
5. Turn the gaps into a twelve-month improvement roadmap and set the reassessment cadence and owner.

DELIVERABLE

A governance maturity self-assessment and improvement roadmap.

CHECK YOUR WORK

- Scores are evidence-based.
- Effectiveness is judged by outcomes.
- Reassessment has a date and owner.

LAB 32 · VIDEO 32 60 MIN

Your Path Forward

Objective. Assess your own skills against the course and choose a specialization.

Inputs. All artifacts. Video 32 notes.

STEPS

1. Rate yourself 1–5 on each part of the course, citing the artifact that proves it.
2. Compare specializations: risk management, compliance, audit, privacy, and the CISO and executive track.
3. Choose one specialization and the certification that best signals it.
4. Choose a practice habit: an organization to analyze, a regulatory source to follow, a failure to study each month.
5. Write a 90-day plan with weekly actions and a checkpoint at day 30, 60 and 90.

DELIVERABLE

A personal skills self-assessment and 90-day development plan.

CHECK YOUR WORK

- Self-ratings cite evidence.
- The specialization choice is justified by strengths and interest.
- The plan has concrete weekly actions.

Appendix: Artifact checklist

Tick each artifact as it is filed. Lab 29 assumes all of Labs 1–28 are complete; Lab 30 audits them.

	LAB	ARTIFACT	FEEDS
☐	01	Governance / management / controls model	Every part boundary
☐	02	Governance failure catalog	Labs 30, 31
☐	03	Case-study organization profile	Every later lab
☐	04	Governance decision framework	Applied throughout
☐	05	Framework selection matrix	Labs 10, 19, 20
☐	06	Structure and decision-rights matrix	Labs 7, 8, 21, 29
☐	07	Board oversight charter	Labs 22, 29
☐	08	Governance RACI matrix	Labs 14, 23, 29
☐	09	Stakeholder engagement plan	Labs 10, 26
☐	10	Policy framework and sample policy	Labs 11, 19, 20
☐	11	Documentation and evidence structure	Labs 20, 21
☐	12	Risk appetite statement and lifecycle	Labs 13, 14, 22, 25
☐	13	Top-risk assessment	Labs 14, 17, 24
☐	14	Risk register with owners	Labs 15–17, 22, 25
☐	15	Third-party risk process and assessment	Labs 16, 19
☐	16	Continuity governance structure	Labs 23, 29
☐	17	Strategic and emerging risk assessment	Labs 24, 28
☐	18	Obligations inventory	Labs 19, 20
☐	19	Regulation-to-control mapping	Labs 20, 21, 23
☐	20	Compliance program design	Labs 21, 22
☐	21	Audit-readiness framework	Labs 22, 30

	LAB	ARTIFACT	FEEDS
☐	22	Reporting framework and board dashboard	Labs 29, 31
☐	23	Security operations governance structure	Lab 29
☐	24	Strategy and maturity roadmap	Labs 25, 29, 31
☐	25	Investment case and budget framework	Lab 29
☐	26	Culture and awareness program	Labs 27, 29
☐	27	Ethics and responsible-technology framework	Lab 28
☐	28	Emerging technology and AI framework	Lab 29
☐	29	Integrated governance program	Labs 30, 31
☐	30	Failure-mode audit	Lab 31
☐	31	Self-assessment and improvement roadmap	Ongoing
☐	32	Skills self-assessment and development plan	Your career